

AuditPledge

Provenance and priced risk for the MCP tools a Compound agent calls

An AI agent that manages a Compound position is only as trustworthy as the **weakest tool** in its toolbelt. AuditPledge checks the provenance of every tool, scores the risk for what a Compound position exposes, and **prices** it in dollars.

A candidate entry to the Compound Grants Program, Security Tooling domain · testnet and seeded only

doom2quake · Dipankar Sarkar

The gap that costs money

DeFi is being wired up to AI agents: position managers, rebalancers, treasury assistants. They acquire tools over the **Model Context Protocol** (MCP), ahead of any security convention for it.

- A tool manifest is **attacker-controlled data**. A tool that claims a publisher and claims a signature proves nothing.
- One unsigned, remote-code-capable, over-scoped tool can read a signing key, rewrite a transaction before broadcast, or **move collateral**.
- The operator has no standard way to answer: *which of the tools my agent can call are dangerous, how dangerous, and in money?*

Supply-chain attacks are already how real systems get breached. The MCP tool layer imports every one of those failure modes and adds a live wire to a wallet.

Why Compound, why now

Compound's Grants Program names **Security Tooling** as a funded domain, run milestone by milestone. A security tool is not a one-shot deliverable; it is an artifact the ecosystem keeps using.

- Not a chain-agnostic tool with a Compound label. The risk model is **weighted for Compound position exposure**: state readers, transaction builders, collateral movers.
- The reference keyring is seeded from publishers the Compound community can vet.
- The moment to set the norm that a tool a Compound agent calls carries verifiable provenance is **before an incident sets it the hard way**.

What AuditPledge does

Open a **real MCP session** → verify provenance → score → price → reprice a fix.

```
$ auditpledge audit --server compound-position-agent --source mcp --no-llm
critical=2 unsigned-RCE=2 position-exposed=2 forged-signatures=0

collateral-mover [critical] score=20 signed=NO publisher=defi-rando
  - RCE-capable ops: ['run_command','os.system','sign_tx']
  - Compound position exposure: ops ['sign_tx']
tx-builder [critical] score=21 signed=NO publisher=txkit
  - Compound position exposure: ops ['sign_tx'] scopes ['build:tx','sign:tx']

worst tool: tx-builder [critical] score=21
```

Every ambiguous path **fails closed**: unknown servers, identity mismatches, forged or missing signatures never read as clean.

Provenance is not a claim

Each tool carries a detached **Ed25519** signature over the canonical bytes of `name, version, publisher, sorted scopes, sorted ops`.

- Only a signature that **verifies** against the committed public keyring counts as signed.
- Publishers are matched **exactly** after normalisation: `attacker.compound-finance` is not `compound-finance`. No suffix matching, ever.
- Edit one character of a signed tool and it flips to unsigned. A present-but-invalid signature is recorded as **forged**.

The demo publishers' private keys ship on purpose, so the offline catalogue carries genuine signatures a reviewer can break. The verifier never imports the signing module.

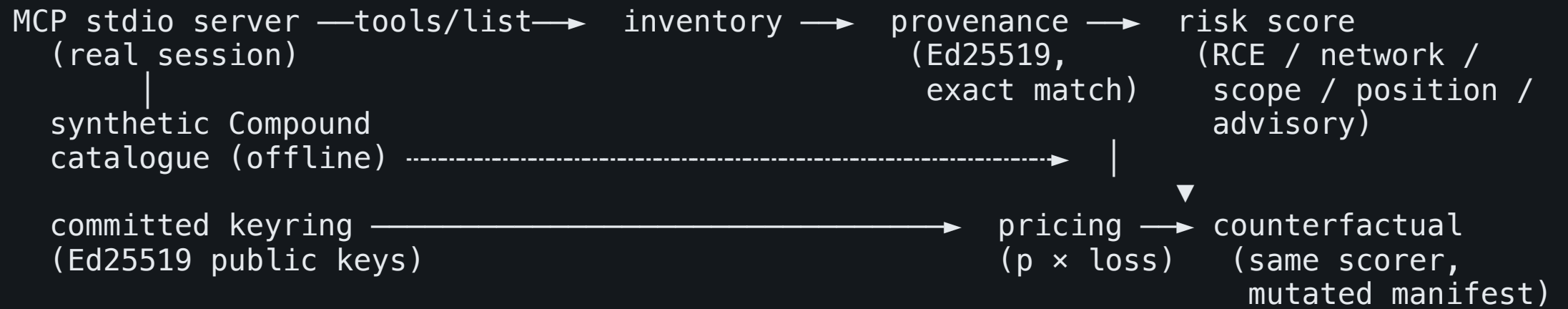
Risk, in money, with a measured fix

An underwriter pass turns the assessment into an expected loss and a premium. RCE-class ops, `sign_tx`, over-broad scopes, unsigned provenance, and Compound position exposure each carry a named weight.

	premium
baseline (worst tool = <code>tx-builder</code>)	\$427,000
drop <code>tx-builder</code> from the toolset	\$217,000 (-210,000)
re-sign by a trusted publisher, sandboxed	\$392,000 (-35,000)

The counterfactual reruns the **identical scorer** over a mutated, genuinely re-signed manifest, so the saving from a fix is **measured, not asserted**.

Architecture



A pure function of the manifest plus the keyring. A reviewer can trace every number, and tests/ pins each rule.

Evidence we ship

- **75 Python tests** pass (`PYTHONPATH=. pytest -q`), no network, key, or cloud credentials.
- A real MCP stdio subprocess test: handshake, `tools/list`, identity mismatch, missing evidence, unreachable server, all fail closed.
- The Ed25519 tamper cases, the unsigned-RCE pricing floor, the counterfactual repricing, the advisory-ID validation, the agent-graph ordering.
- A **UI that cannot lie**: every number is captured from a real run, and a snapshot test fails if the page drifts.

Every defence in this repo has a test that fails without it. No test is weakened to make it pass.

Milestone roadmap

M1 — built and green. This repo: the engine, Compound-tuned, real MCP session, priced report. *(75 tests pass.)*

M2 — provenance evidence spec + signing kit. A versioned schema for Ed25519 evidence in an MCP tool's `_meta`, and a CLI a tool author uses to sign their manifest.

M3 — live advisory feed + testnet reference. OSV.dev exercised live; a hosted report viewer; a documented run against a Compound-facing agent on **testnet**.

M4 — docs, hand-off, adoption. A builder's guide, outreach to Compound tool authors.

All Web3 interaction is testnet and seeded only for the grant period.

Honest limits

- **No users, no mainnet deployment, no revenue.** Nothing touches Compound mainnet.
- **No third-party MCP server audited yet.** Against a tool that publishes no provenance, the auditor fails closed rather than inventing a verdict (that is what M2 delivers).
- **Pricing inputs are illustrative priors,** not an actuarial model. The mechanism is the point: a manifest becomes a reproducible number; a fix changes it by a measured amount.
- **No audit, partnership, or endorsement** from Compound, Compound Governance, the grants program, or Questbook. This is a grant **application**.

The full map is in docs/HONESTY.md.

Built for Compound

[compound.finance](#) ·

[comp.xyz](#) ·

Compound Grants Program via [Questbook](#)

A provenance-and-pricing standard proven against Compound-facing agents is a public good the whole ecosystem inherits. Open, MIT-licensed, testnet and seeded only.

This is an application. No partnership, no endorsement, no mainnet.

Live demo: <https://doom2quake.github.io/compound-grants/ui/>